

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 1 頁，共 15 頁

單選題 50 題 (佔 100%)

C	1. ISO/IEC 27001 :2022 相較 ISO/IEC 27001 :2013，主要新增控制措施「不」包括下列何項？ (A) 新增使用雲端服務之資訊安全 (B) 新增網頁過濾要求 (C) 新增技術漏洞管理要求 (D) 新增資料洩漏預防要求
D	2. 貴公司是大型銀行的供應商之一，主要負責銀行客戶個資處理及利用；而最近因應數位轉型計劃，打算將相關基礎建設遷移至雲服務，試問為滿足客戶需求及服務品質保證，公司導入下列何種標準最「不」適當？ (A) ISO 27006 (B) ISO 27001 (C) ISO 27701 (D) ISO 27018
B	3. 關於 CNS 27002:2023 國家標準，下列何項描述最為適切？ (A) 特定產業的資訊安全稽核標準 (B) 通用資訊安全控制措施的參考與實作指引 (C) 資訊安全事故的法律訴訟程序 (D) 雲端服務的防護模型
D	4. 資訊安全管理系統 (Information Security Management System, ISMS) 的導入步驟中，稽核活動的主要目的為下列何項？ (A) 確保該管理系統的完整性 (B) 評估員工的績效表現 (C) 檢查環境硬體設備的完整程度 (D) 確保該管理系統內部控制的有效性

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 2 頁，共 15 頁

D	5. 關於保護資料之機密性、完整性與可用性描述，下列何項正確？ (A) 應用系統的可用性對組織而言，皆為同等級重要 (B) 公司內部員工的個人資訊，不在機密性的保護範圍 (C) 保護資料之機密性、完整性與可用性而言，機密性最為重要 (D) 組織之公開資訊對外公布時，資料的完整性需審查後再開放
D	6. 下列「資通安全管理法」的哪一項子法，有明確規範資通安全演練作業項目？ (A) 資通安全責任等級分級辦法 (B) 資通安全管理法施行細則 (C) 資通安全情資分享辦法 (D) 資通安全事件通報及應變辦法
A	7. 甲公司擬以網路行銷為特定目的，透過其官方網站之會員註冊頁面向乙蒐集個人資料。依《個人資料保護》及其主管機關解釋規範，關於甲蒐集與行銷利用乙之個人資料，下列何者為錯誤的敘述？ (A) 乙應就同意甲蒐集其個人資料之事實負舉證責任 (B) 蒐集個人資料時，尊重當事人之權益，並依誠實及信用方法為之 (C) 向當事人蒐集個人資料時，明確告知當事人網路行銷之特定目的 (D) 甲於首次行銷時，應提供乙表示拒絕接受行銷之方式，並支付所需費用
C	8. 有關個人資料保護法的立法目的之敘述，下列何者最為正確？ (A) 保障國家安全與社會秩序 (B) 促進電子商務發展 (C) 避免人格權受侵害，並促進個人資料之合理利用 (D) 管制資訊流通速度

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 3 頁，共 15 頁

D	9. 依個人資料保護法對於個人資料之定義，下列何者「不」屬於個人資料的範疇？ (A) 社群帳號 (B) 指紋 (C) 性生活 (D) 公司統一編號
A	10. 關於資通安全管理法對於委託機關於委外辦理資通系統之建置、維運或資通服務之提供，選任及監督受託者時，應注意「適任性查核」的敘述，下列何者錯誤？ (A) 應查核有無曾犯洩密罪，或於動員戡亂時期終止前，犯內亂罪、外患罪，經判刑確定，或通緝有案尚未結案 (B) 應查核有無曾犯洩密罪，或於動員戡亂時期終止後，犯內亂罪、外患罪，經判刑確定，或通緝有案尚未結案 (C) 應查核有無曾受到外國政府之利誘、脅迫，從事不利國家安全或重大利益情事 (D) 應查核有無曾受到大陸地區、香港或澳門政府之利誘、脅迫，從事不利國家安全或重大利益情事
C	11. 關於中華民國「資通安全管理法」中「特定非公務機關」之條文敘述，下列何項錯誤？ (A) 特定非公務機關為因應資通安全事件，應訂定通報及應變機制 (B) 特定非公務機關於知悉資通安全事件時，應向中央目的事業主管機關通報 (C) 特定非公務機關應向中央目的事業主管機關提出資通安全事件調查、處理及改善報告；資通安全事件不分等級，皆應由資安長召開會議研商相關事宜 (D) 知悉重大資通安全事件時，主管機關或中央目的事業主管機關於適當時機得公告與事件相關之必要內容及因應措施，並得提供相關協助

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 4 頁，共 15 頁

B	12. 請問下列何項個資當事人權利為歐盟 GDPR 賦予，但我國個人資料保護法卻未明確提及的權利？ (A) 個人資料的刪除權 (B) 個人資料的可攜權 (C) 個人資料的同意權 (D) 個人資料的更正權
C	13. 如附圖所示，在能清楚識別當事人的情況下，下列何項組合可能會侵犯當事人的個人資料？ 1. 參與車禍現場救援後，在臉書分享傷者照片 2. 公司內部通知全體員工某人升遷的消息，並附上姓名和照片 3. 里長在電線桿上張貼寵物主人放任狗隨地大小便的照片 4. 學校經當事人同意，在官網公開優秀學生的名字及獲獎成績 5. 新聞媒體報導某公眾人物參加公開活動的照片 6. 店家在網路上公告被竊盜的監控錄影影片 7. 學校在家長群組中傳播某學生的成績單以進行討論 (A) 1、2、3 (B) 3、4、7 (C) 1、3、7 (D) 5、6、7
A	14. 下列何項「不」屬於資訊資產分類時需考量的依據？ (A) 鑑別性 (B) 可用性 (C) 完整性 (D) 機密性
D	15. 資訊資產管理中要求對每項資產指定一位「資產擁有者」，該人員指的是下列何項？ (A) 實際使用該資產的人或部門 (B) 對資產提供技術支援的人或部門 (C) 決定是否採購資產的人或部門 (D) 對資產負有管理責任的人或部門

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 5 頁，共 15 頁

D	16. 在資訊資產盤點中，若發現某些資產因技術更新而變得不再具備相同的商業價值，最適合的後續處理方式為下列何項？ (A) 按重新對資產進行分類並降級，但保留原始存取控制 (B) 徹底移除該資產的分類與保護，轉交給資產報廢小組 (C) 根據風險評估，繼續保留該資產的現有分類與保護 (D) 降低資產保護等級，但仍需定期進行風險評估與監控
B	17. 如附圖所示。企業為確保資通系統及資產得以識別，進行資通資產分類時，其中定義資產種類包含主要性 (primary) 資產及支援性 (supporting) 資產等兩種類型。請問，下列何項資產及類型配對結果為正確？ 1. 資訊 (information)：主要性 2. 硬體 (hardware)：主要性 3. 網路 (network)：支援性 4. 人員 (personnel)：主要性 5. 業務流程 (business processes)：支援性 6. 企業活動 (business activities)：主要性 (A) 1、4、6 (B) 1、3、6 (C) 2、3、5 (D) 2、4、5
C	18. 在工控製造環境中，下列何者最適合被歸類為「關鍵資產」？ (A) 辦公室的印表機 (B) 控制廠區照明的智慧燈具 (C) 工廠生產線的 PLC (可程式邏輯控制器) (D) 公司員工帳號

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 6 頁，共 15 頁

B	19. 依據 CNS 27002：2023 資訊安全、網宇安全及隱私保護-資訊安全控制措施，所有對組織具價值的「資產」都可區分為下列哪兩大類別？ (A) 資訊及實體 (B) 主要資產及支援資產 (C) 硬體及軟體 (D) 內部資產及外部資產
B	20. 關於資訊資產盤點作業的描述，下列何者最「不」適當？ (A) 資訊資產盤點即是資訊設備盤點 (B) 資訊資產盤點在確認資產的殘值 (C) 資訊資產盤點應考量全面性 (D) 資訊資產盤點應確認資產的可用性
D	21. 下列何種「不」是風險處理的策略之一？ (A) 風險降低 (Risk Reduction) (B) 風險避免 (Risk Avoidance) (C) 風險轉移 (Risk Transfer) (D) 風險拒絕 (Risk Reject)
C	22. 關於資通安全風險處理內容的描述，下列何者較為正確？ (A) 風險保留 (Risk Retention) 是組織避免接受任何風險的做法，確保避開所有可能對組織產生負面影響的風險 (B) 風險修改 (Risk Modification) 是指組織不對風險採取任何行動，接受風險的存在並準備承擔其後果 (C) 風險分擔 (Risk Sharing) 是透過與其他組織或他方分享風險來分散風險，例如透過保險或委外來達成 (D) 風險避免 (Risk Avoidance) 是指組織採取措施主動減少風險的可能性和影響，例如通過技術改進或政策更新

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 7 頁，共 15 頁

B	23. 風險處理活動是依照風險評鑑結果及實作風險處理方案之預期成本及預期利益等，選擇適當之行動方案，以使風險之不利後果能合理的降低，風險處理活動之選項主要有風險修改（Risk Modification）、風險保留（Risk Retention）、風險避免（Risk Avoidance）及風險分擔（Risk Sharing）等 4 種。請問下列何種情境最適合運用「風險分擔」來處理？ (A) 電腦機房的滅火設施老舊 (B) 座落於洪災頻繁區域的機房大樓 (C) 隨身碟遺失的可能性 (D) 滿腹牢騷的員工所造成蓄意破壞的威脅
B	24. 在工控資安的風險管理流程中，下列何者屬於風險處理（Risk Treatment）的措施？ (A) 識別 PLC 與 SCADA 系統清單 (B) 決定是否採取風險接受、風險降低、風險轉移或風險避免等措施 (C) 建立風險矩陣並評分 (D) 召開資產盤點會議
A	25. 如附圖所示。你是一位電子商務公司的資安管理人員，經由外部資安廠商進行評估後發現其公司電子商務網站存在 SQL 注入（SQL Injection）漏洞。駭客可以利用此漏洞竊取大量客戶資料，導致企業形象及名譽的受損，也需要負責法律上的責任。請參考附圖 NIST 通用風險模型（The NIST Generic Risk Model），指出上述內容的「脆弱性」（Vulnerability）為下列何項？

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 8 頁，共 15 頁

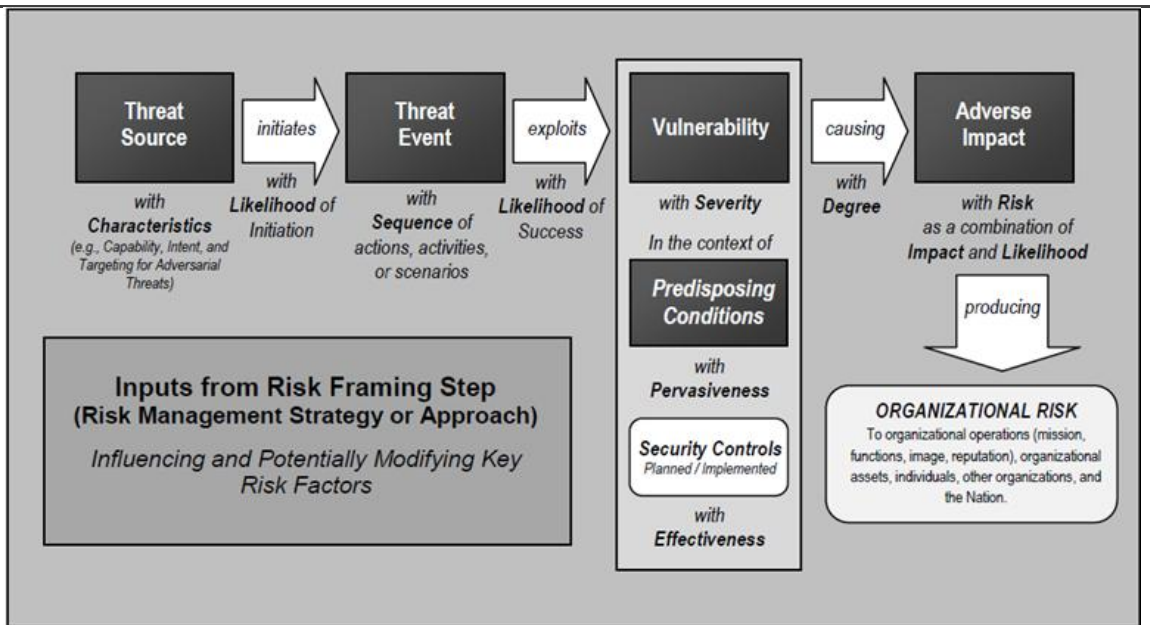


FIGURE 3: GENERIC RISK MODEL WITH KEY RISK FACTORS

- (A) 網站存在 SQL 注入漏洞
- (B) 客戶資料外洩
- (C) 企業形象及名譽的受損任
- (D) 駭客（惡意攻擊者）

- C 26. FIDO (Fast Identity Online) 是無密碼登入解決方案，主要是透過公開金鑰加密的架構結合終端裝置的多重因素驗證 (MFA) 與生物辨識驗證進行登入動作，可以更嚴密地保護個資。請問下列關於 FIDO 的描述何者較「不」正確？
- (A) FIDO 的三大認證協議分別為 FIDO UAF、FIDO U2F、FIDO2
 - (B) FIDO 的最大特色是所有協定都建立於公開金鑰加密上，讓伺服器端只保存公鑰，不再需要負責保管使用者個資
 - (C) 使用者於各家金融機構先進行身分驗證開通「金融 FIDO」的使用，就可以利用個人終端裝置而不需要攜帶金融卡進行各項金融服務的驗證
 - (D) 使用者可以在終端裝置上透過指紋辨識、聲音辨識、輸入個人識別碼 PIN 等方式進行線上登入

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 9 頁，共 15 頁

A	27. 在零信任架構 (Zero Trust Architecture, ZTA) 實作參考原則中，下列何者描述與應用程式的存取授權最直接相關？ (A) 以作業屬性及風險區隔角色，並依角色風險等級定義授權條件（如身分及設備鑑別之等級），採最小授權原則定義授權範圍；並針對特權作業採獨立角色授權（不混用於非特權作業），減少特權帳號之濫用及風險 (B) 對網路連線紀錄具有即時偵測及回應機制（如 NDR），可因應業務需求、偵測到入侵指標（IOC）或遭受攻擊時，動態調整網路設定（如調整網路防護邊界即時隔離、切換備援路由或資源配置等）或即時告警，以維持網路服務，將對業務影響最小化 (C) 具網段隔離機制，採最小需求原則限制存取資源之網路連線，並得限制同網段主機間連線及資源存取，防止攻擊者利用遭入侵的主機作為跳板機進行橫向擴散 (D) 具有效盤點且可唯一識別（如 TPM 等）納管設備機制，並對其安全要求（如病毒碼、作業系統狀態等）之判斷及應處機制；對未納管設備具有即時偵測及風險控管（如強制隔離）機制
B	28. 關於零信任（Zero Trust）的敘述，下列何者正確？ (A) 零信任是不用始終驗證 (B) 僅提供必要的權限 (C) 不需保持網路可見性 (D) 非所有流量都是不安全的前提下進行零信任設計

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 10 頁，共 15 頁

D	29. 當使用者主張自己的身分後，系統應該確認使用者是否為所宣稱的合法身分擁有者，這個證明使用者身分的過程就被稱為「身分驗證」(Authentication)。關於常見身分驗證方法中的所具之形 (Something you Are)，下列敘述何者最「不」適切？ (A) 指紋 (Fingerprints) (B) 視網膜 (Retina) (C) 掌形 (Palm) (D) 個人密碼 (Password)
D	30. 關於最小權限 (Least Privilege) 原則的描述，下列何項描述最為適切？ (A) 應授予所有使用者系統管理員權限，以提高效率 (B) 應根據使用者在組織階層中的級別來授予權限 (C) 所有使用者應享有相同的權限，以確保公平 (D) 僅授予使用者完成其工作所必需的最低權限
C	31. 關於預設拒絕 (Deny by Default) 原則的描述，下列何項描述最為適切？ (A) 除非使用者明確要求，否則所有功能預設為啟用 (B) 應用程式應預設允許所有請求，除非有規則明確拒絕 (C) 當沒有任何存取控制規則明確符合時，應預設拒絕存取請求 (D) 只有被列入黑名單的使用者才被拒絕存取
C	32. 下列何者「非」重要系統權限管理常見之安全管理措施？ (A) 系統權限申請必須經過權責主管核准 (B) 臨時權限到期即自動停用 (C) 每月備份重要系統 (D) 每半年定期檢視管理者及使用者權限是否異常

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 11 頁，共 15 頁

A	33. 關於屬性存取控制（Attribute Based Access Control, ABAC）其中之「主體（subject）」，下列何項描述最為適切？ (A) 對物件執行操作的角色，如：使用者 (B) 需要被保護的系統資源，如：檔案、資料庫 (C) 規範存取規則的政策文件，如：防火牆規則 (D) 定義操作情境的環境條件，如：時間、地點
C	34. 關於應用程式之授權檢查（Authorization Checks）最佳實務，下列何項描述最為適切？ (A) 僅在客戶端（Client-side）執行，以提升使用者體驗 (B) 僅在使用者首次登入時執行一次，以提升伺服器效能 (C) 必須在伺服器端（Server-side）執行，以提昇安全性 (D) 可由使用者自行選擇是否執行，以兼顧便利與安全性
B	35. 如附圖所示，為有效強化身分認證機制，常會使用多因子（Multi-factor authentication, MFA）認證機制，下列哪一項應用組合屬於多因子認證類型？ 1. 聲紋辨識+帳號密碼（Password） 2. 指紋辨識+圖形驗證碼（Captcha） 3. 臉型辨識+指靜脈辨識+虹膜 4. 帳號密碼+自然人憑證 IC 卡 5. 帳號密碼+虹膜+自然人憑證 IC 卡 6. 帳號密碼+指紋辨識+圖形驗證碼（Captcha） (A) 1、2、3、5 (B) 1、4、5、6 (C) 1、2、3 (D) 2、3、5

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 12 頁，共 15 頁

A	36. 加密與解密使用不同的金鑰，稱為公開金鑰演算法，或非對稱金鑰演算法，下列密碼演算法中，何者屬於此種加密演算法？ (A) RSA (B) DES (C) AES (D) Blowfish
A	37. 關於金鑰管理生命週期的描述，下列何項正確？ (A) 金鑰管理的安全要求，必須包含從產生、儲存、分發、管理到銷毀整個生命週期 (B) 金鑰的使用因為內部資安預算分配考量，應以使用免費金鑰為優先 (C) 因為應用系統皆須使用金鑰考量，管理的權限可開放使用 (D) 因為金鑰有使用期限的設定，超過有效期限之金鑰可以不需要替換
C	38. 關於金鑰管理之安全考量，下列敘述何者較「不」適當？ (A) 應確保金鑰品質（避免產生弱金鑰） (B) 金鑰之使用、儲存、傳送與銷毀，應確保金鑰之內容無洩露之虞 (C) 金鑰應儲存於通過 FIPS 140-2 Level3（含）以上之硬體安全模組內並可明文匯出 (D) 金鑰應備份，並妥適保管，以確保其可用性
B	39. 請問下列何項其主要用途是用於解密資料？ (A) 公鑰 (B) 私鑰 (C) 數位簽章 (D) 訊息摘要

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 13 頁，共 15 頁

B	40. 關於雜湊函數（Hash function）的主要用途說明，下列何項描述最為適切？ (A) 對訊息進行加密以保護其隱私 (B) 生成訊息摘要（Message digest）來驗證完整性 (C) 建立秘密金鑰（Secret key）以用於對稱加密 (D) 在加密過程中隨機化明文
D	41. 有關資安事件是否需要通報的判斷依據，下列何者較「不」適當？ (A) 根據事件的嚴重性等級 (B) 依據主管機關的法規要求 (C) 根據事故管理計畫的規定 (D) 依據事件鑑識人員的現場判斷
C	42. 下列何項「不」是資訊安全事故管理計畫需考量的程序？ (A) 制訂資訊安全事故準則 (B) 分析及通報資訊安全事故 (C) 損失與賠償 (D) 存錄事故管理活動
C	43. 如附圖所示。美國「網路安全暨基礎設施安全局」（CISA）規範了用以識別及分類資通安全威脅情資（Cyber Threat Intelligence, CTI），並指定可以閱讀或共享 CTI 接收者的管理指導準則《Traffic Light Protocol 2.0 User Guide》，其中規範 CTI 敏感程度的 TLP（Traffic Light Protocol）標籤共有 4 種。請問是下列何項？ 1. RED 2. GREEN 3. BLACK 4. BLUE 5. WHITE 6. CLEAR 7. AMBER

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 14 頁，共 15 頁

	(A) 1、2、3、4 (B) 2、3、5、6 (C) 1、2、6、7 (D) 1、4、5、7
B	44. 在資安事故管理中，下列何項措施最能提升企業的資安韌性？ (A) 購買效能更好的資安設備 (B) 建立適合的資安架構，並定期進行演練 (C) 增加資安預算、招募專業的監控人員 (D) 將所有資安工作外包給第三方廠商
B	45. 如附圖所示，在資安事件處理的偵測與分析階段中，下列哪一項行為最有助於快速辨識是否為資安事件？ X 公司資安監控中心 (Security Operations Center, SOC) 於尖峰時段收到多來源告警： ● 入侵偵測系統 (Intrusion Detection System, IDS) 出現可疑掃描行為 ● 端點偵測與回應 (Endpoint Detection and Response, EDR) 回報異常 PowerShell 程式啟動 ● 安全資訊與事件管理 (Security Information and Event Management, SIEM) 將多筆事件關聯後提升為高風險 (A) 立即關閉受影響系統以防止可能的擴散 (B) 對相關系統與網路設備進行日誌 (Log) 關聯分析，比對入侵指標 (Indicators of Compromise, IOC) 並確認事件是否成立 (C) 依內規直接向主管機關進行對外通報 (D) 優先套用廠商最新修補 (Patch) 以移除可能弱點
B	46. 下列何項是確保數據中心備援運作有效的最佳做法？ (A) 定期進行員工輪調 (B) 定期測試備份系統 (C) 定期進行財務審查 (D) 減少數據中心的外圍安全措施

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

卷號：I11-4201

考試日期：114 年 11 月 8 日

第 15 頁，共 15 頁

A	47. 關於營運持續管理之敘述，下列何者最「不」正確？ (A) 營運持續管理是資訊安全部門的權責，故無需其他部門人員參與 (B) 營運持續管理包含緊急災害復原計畫 (C) 營運持續管理應與公司目標、政策一致 (D) 營運持續管理應適時調整、更新
B	48. 工控環境中，營運持續管理規劃的首要目的為何？ (A) 確保公司網站維持最新設計 (B) 在事故發生後，確保關鍵工控系統能持續或迅速恢復運作 (C) 減少員工流動率 (D) 強化社群媒體行銷
C	49. 在營運持續運作管理程序中，下列何項「不」是營運衝擊分析（Business Impact Analysis, BIA）的主要步驟？ (A) 識別機關的核心業務功能 (B) 計算核心業務可容許缺少資源的時間 (C) 制定詳細的災害復原技術操作手冊 (D) 確認業務功能與資源復原的先後順序
B	50. 下列何項敘述是資料備份的主要目的？ (A) 確保資料的機密性，防止未經授權的存取 (B) 對抗資料毀損的威脅與抵抗勒索攻擊，以保護資料的可用性 (C) 確保資料的機敏性，防止資料遭到竄改 (D) 降低營運成本，減少儲存需求